

AIDLC Pharma-RAG — V1 vs V2 vs V3 Comparison

Generated 2026-09-26 · V2: architecture review · V3: security review (spec agent)

Area	V1 (initial build)	V2 (2026-09-26, arch review)	V3 (2026-09-26, security review)
Auth	Header inconsistency between frontend/backend	Fixed: consistent X-API-Key contract	Non-constant-time != comparison → hmac.compare_digest
CORS	Wide open	Origins scoped	Methods/headers narrowed from ["*"] to actual set (GET,POST / Content-Type,X-API-Key)
Secrets storage	Provider key world-readable	File permissions 600	Containing directory backend/.runtime/ also locked to 700 (was 775)
Timeout / cancel	UI could hang forever on a stuck request	Fixed: timeout + cancel button	—
Input limits	None	None	max_length / min_length on all request fields; ASGI-level MaxBodySizeMiddleware rejects >16KiB before body is buffered (413)
Rate limiting	None	None	Sliding-window limiter (30 req/60s per caller), applied before auth so brute-force attempts are throttled too
Error disclosure	—	—	Raw jsonschema exception no longer echoed to client; logged server-side, generic message returned
Dependency pinning	Unpinned	Unpinned	Pinned to installed versions via pip freeze
XSS regression coverage	Only isHttpRequest() tested	Added XSS regression test	escapeAttr() widened to escape & , ' , backtick (not just "); tests extracted to shared escape.js so tests exercise real code, not duplicated logic
Frontend transport security	Bare python3 -m http.server	—	New serve.py sends CSP, X-Content-Type-Options: nosniff , X-Frame-Options: DENY ; directory listing disabled globally
Server exposure	frontend/tests/ directory-listable	—	Placeholder index.html + serve.py 's listing override closes it
Governance	—	—	New spec peer agent (read-only security reviewer) + human_gate.py gate on finalized security reports, mirroring the existing triage gate

Verified this session, live

No key → 401 · wrong key → 401 (constant-time) · oversized field → 422 · oversized raw body → 413 · .runtime/ perms 700/600 · 30-req/60s rate limit trips correctly · frontend headers present · /tests/ no longer lists · human_gate.py asks on the finalized report, silent on the draft.

Known gaps still open (finalized report, not actioned)

- **P2-2:** `backend/src/utils/allowlist.py` checks host, not URL scheme — a non-http(s) scheme against an allowlisted host isn't rejected.
- **P3-4:** backend API itself has no `X-Content-Type-Options: nosniff` (only the frontend's `serve.py` got it).
- **C1/C2** (Critical, documented not fixed): the shared `X-API-Key` is embedded in publicly-served `frontend/app.js` — real end-user auth was never in scope for this POC's trust model, and `backend/README.md` now says so explicitly rather than silently leaving it as an apparent oversight.

Sources: [reports/code-review/2026-09-26-v2-improvement-review.md \(V1→V2\)](#) · [reports/spec/2026-09-26-v3-security-review.md \(V2→V3\)](#)